Lab 5: Static Code Analysis
Supplier Purchase Order Tracker (supplier_orders.py)

Name: Anvi Srinivas
SRN : PES1UG24CS076
Class : 5B

1.Introduction

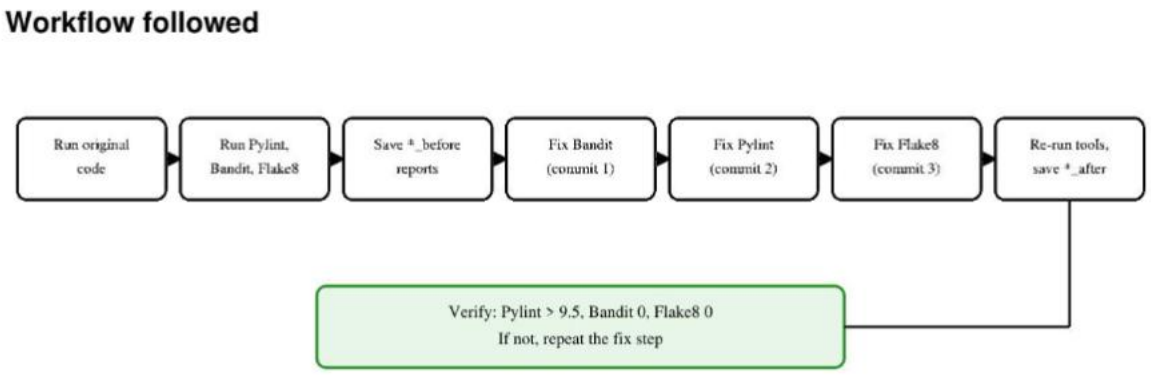
Static code analysis examines source code without executing it to find bugs, security vulnerabilities and style violations early, before they reach testing or production. It is automated, fast and repeatable, and it enforces a consistent standard across a team.

Tool	Role	Looks for
Pylint	Strict code reviewer	Logic and quality issues: unused arguments, bad naming, missing docstrings, broad exceptions, globals; gives a score out of 10.
Bandit	Security guard	Insecure patterns: shell injection, SQL injection, silent try/except/pass, unsafe subprocess use; rated by severity and confidence.
Flake8	Grammar checker	PEP 8 style: line length, blank lines, whitespace around operators, unused imports

About the program

A purchase order tracker for a stores department. It places orders with suppliers (SQLite), marks deliveries as received, notifies the warehouse and cleans up fulfilled orders. Demo output of the original and the fixed program is identical: 54 0.

Workflow followed



1. Issues identified before fixing

Pylint (before)

```
$ pylint supplier_orders.py > pylint_report.txt && cat pylint_report.txt
************* Module supplier_orders
supplier_orders.py:5:0: C0301: Line too long (122/100) (line-too-long)
supplier_orders.py:11:0: C0301: Line too long (131/100) (line-too-long)
supplier_orders.py:1:0: C0114: Missing module docstring (missing-module-docstring)
supplier_orders.py:6:0: C0103: Constant name "order_total" doesn't conform to UPPER_CASE naming
    style (invalid-name)
supplier_orders.py:9:0: C0116: Missing function or method docstring (missing-function-docstring)
supplier_orders.py:9:0: C0103: Function name "placeOrder" doesn't conform to snake_case naming style
     (invalid-name)
supplier_orders.py:9:15: W0621: Redefining name 'conn' from outer scope (line 4) (redefined-outer-
    name)
supplier_orders.py:10:4: W0603: Using the global statement (global-statement)
supplier_orders.py:11:17: C0209: Formatting a regular string which could be an f-string (consider-
    using-f-string)
supplier_orders.py:16:0: C0116: Missing function or method docstring (missing-function-docstring)
supplier_orders.py:16:0: C0103: Function name "markReceived" doesn't conform to snake_case naming
    style (invalid-name)
supplier_orders.py:16:17: W0621: Redefining name 'conn' from outer scope (line 4) (redefined-outer-
    name)
supplier_orders.py:16:33: W0613: Unused argument 'remarks' (unused-argument)
supplier_orders.py:20:0: C0116: Missing function or method docstring (missing-function-docstring)
supplier_orders.py:20:0: C0103: Function name "notifyWarehouse" doesn't conform to snake_case naming
     style (invalid-name)
supplier_orders.py:24:0: C0116: Missing function or method docstring (missing-function-docstring)
supplier_orders.py:24:12: W0621: Redefining name 'conn' from outer scope (line 4) (redefined-outer-
    name)
supplier_orders.py:27:11: W0718: Catching too general exception Exception (broad-exception-caught)
supplier_orders.py:31:0: C0116: Missing function or method docstring (missing-function-docstring)
supplier_orders.py:31:0: C0103: Function name "pendingCount" doesn't conform to snake_case naming
    style (invalid-name)
supplier_orders.py:31:17: W0621: Redefining name 'conn' from outer scope (line 4) (redefined-outer-
    name)
supplier_orders.py:35:0: C0116: Missing function or method docstring (missing-function-docstring)

-----------------------------------
Your code has been rated at 2.41/10
```

Flake8 (before)

```
oldeis*.py' ù:8Ô: E50Ì luse *oo lony (122      79"c aiacte is) " " "
uicloi',.|Jy:Ţî:80: L5ÔŢ lin o loo low¢ą (Ţ3Î > 79 ciJui*4¢*.=i•,)
olaeis.py:12 îu: E225 rmsszng \vlJzt espace aiound o|Jeiat oi
olders.py:32 80: EoÔ1 lme  loo lowl (87 > 79 rhaiaclols)
```

Bandit (before)



```
$ bandit -r supplier_orders.py > bandit_report.txt && cat bandit_report.txt
[main]  INFO    profile include tests: None
[main]  INFO    profile exclude tests: None
[main]  INFO    cli include tests: None
[main]  INFO    cli exclude tests: None
[main]  INFO    running on Python 3.12.3
Run started:2026-10-30 07:21:56.745077+00:00

Test results:
>> Issue: [B608:hardcoded_sql_expressions] Possible SQL injection vector through string-based query
   construction.
   Severity: Medium   Confidence: Medium
   CWE: CWE-89 (https://cwe.mitre.org/data/definitions/89.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b608_hardcoded_sql_expressions.html
   Location: ./supplier_orders.py:11:17
10      global order_total
11      conn.execute("INSERT INTO orders (supplier, item, quantity, received) VALUES ('%s', '%s',
   %d, 0)" % (supplier, item, quantity))
12      order_total+=quantity

--------------------------------------------------
>> Issue: [B605:start_process_with_a_shell] Starting a process with a shell, possible injection
   detected, security issue.
   Severity: High   Confidence: High
   CWE: CWE-78 (https://cwe.mitre.org/data/definitions/78.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b605_start_process_with_a_shell.html
   Location: ./supplier_orders.py:21:4
20  def notifyWarehouse(supplier):
21      os.system("echo notifying warehouse about " + supplier)
22

--------------------------------------------------
>> Issue: [B110:try_except_pass] Try, Except, Pass detected.
   Severity: Low   Confidence: High
   CWE: CWE-703 (https://cwe.mitre.org/data/definitions/703.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b110_try_except_pass.html
   Location: ./supplier_orders.py:27:4
26          conn.execute("DELETE FROM orders WHERE received = 1")
27      except Exception:
28          pass
29

--------------------------------------------------

Code scanned:
    Total lines of code: 29
    Total lines skipped (#nosec): 0
    Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXX): 0

Run metrics:
    Total issues (by severity):
        Undefined: 0
        Low: 1
        Medium: 1
        High: 1
    Total issues (by confidence):
        Undefined: 0
        Low: 0
        Medium: 1
        High: 2
Files skipped (0):
```

2. Issue identification table

Issue	Type	Line(s)	Description	Fix approach
OS command injection (B605)	Security, High	21	`os.systemruns ashell commandbuiltbysbng concatenaion with supplier`	Removed the shell call; warehouse notice is printed. (A subpEoces s Call was tried first but Bandit still flags B404/B603/B607.)
SQL injection (B608)	Security, Medium	11	INSERT query built with • string formatting	Parameterized query using placeholders
Silent broad except (B110, W0718)	Security/Bug , Low	27-28	`except Exception: pass` hides all failures	`Catchsqlite3.Erroronly` and log it
Global state (W0603)	Design	10, 12	`global order_totalmuated` across calls	Compute the total with SELEC7 `SUM(quantity)`
Redefined outer name (W0621)	Quality	4, 9, 16, 24, 31	Module-level conn Shadowed by every function parameter	Create conn inside main ( )
Unused argument (W0613)	Quality	16	`remarks neverusedin markReceived`	Log the remarks
Naming (C0103)	Style	9, 16, 20, 31	**`camelCasetuncflon names;`** `order_totalaSCorStant`	Renamed to snake case; removed the module constant
Missing docstrings (C0114, C0116)	Style	1, all defs	No module or function docstrings	Added docstrings
Line too long (C0301, E501)	Style	5, 11, 32	Lines of 122, 131 and 87 characters	Wrapped to under 79 characters
Missing whitespace (E225)	Style	12	`order_total+=quantity`	Line removed with the global fix
No main guard	Bug	44	maie ( ) runs on import	`Addedif enamel == " main ":`

Commits (one per tool)

Commit	Fixes	Result
1: Fix Bandit issues	Shell call removed, parameterized SQL, specific exception with logging	Bandit: 3 issues to 0
2: Fix Pylint issues	snake case, docstrings, no global, no shadowing, unused arg, main guard	Pylint: 2.41 to 10.00
3: Fix Flake8 issues	Line lengths and remaining PEP 8 formatting	Flake8: 4 issues to 0

3. Before-and-aRer outputs (contents of all six reports)

pylint_before.txt

```
************* Module supplier_orders
supplier_orders.py:5:0: C0301: Line too long (122/100) (line-too-long)
supplier_orders.py:11:0: C0301: Line too long (131/100) (line-too-longl
supplier_orders.py:1:0: C0114: Missing module docstzing (missing-module-docstringl
supplier_orders.py:6:0: C0103: Constant name "order_total’ doesn't conform to UPPER_CASE naming style (invalid-name}
supplier_orders.py:9:0: C0116: Missing function oz method docstring (missing-function-docstring}
supplier_orders.py:9:0: C0103: Function name "placeOrder" doesn't oonfozm to snake_case naming style linvalid-name)
supplier_orders.py:9:15: W062l: Redefining name 'conn' from outer scope (line 4) lzedefined-outer-name)
supplier_orders.py:10:4: W0603: Using the global statement  lglobal-statement)
supplier_orders.py:11:17: C0209: Formatting a regular string whioh could be an I-string (consider-using-f-stringl
supplier_orders.py:16:0: C0116: Missing function or method docstring (missing-function-docstring)
supplier_orders.py:16:0: C0103: Function name "mazkReoeived’ doesn't conform to snake_oase naming style (invalid-name)
supplier_orders.py:16:17: W062l: Redefining name 'conn' from outer scope (line 4) (redefined-outer-name)
supplier_orders.py:16:33: W0613: Unused argument 'remarks' (unused-argument}
supplier_orders.py:20:0: C0116: Missing function or method docstring (missing-function-docstring)
supplier_orders.py:20:0: C0103: Function name 'notifyWarehouse" doesn't conform to snake_case naming style (invalid-name)
supplier_orders.py:24:0: C0116: Missing function or method docstring (missing-function-docstring)
supplier_orders.py:24:12: W062l: Redefining name 'conn' from outer scope (line 4) (redefined-outer-name)
supplier_orders.py:27:11: W0718: Catching too general exception Exception {broad-exception-caught}
supplier_orders.py:31:0: C0116: Missing function or method docstring (missing-function-docstring)
supplier_orders.py:31:0: C0103: Function name 'pendingCount' doesn't conform to snake_oase naming style (invalid-name)
supplier_orders.py:31:17: W062l: Redefining name 'conn' from outer scope (line 4) (redefined-outer-name)
supplier_orders.py:35:0: C0116: Missing function or method docstring (missing-function-docstring)


Your code has been rated at 2.41/10
```

pylint_aher.txt

```
Your code has been rated at 10.00/10
```

bandit_before.txt

```
[main]  INFO    profile include tests: None
[main)  INFO    profile exclude tests: None
[main)  INFO    cli include tests: None
[main]  INFO    cli exclude tests: None
[main]  INFO    running on Python 3.12.3
Run started:2026-10-30 07:21:56.74fi077+00:00

Test results:
>> Issue: 1B608:hardcoded_sql_expressions] Possible SQL injection vector through string-based query construction.
   Severity: Medium   Confidence: Medium
   CWE: CWE-89 (https:7/cwe.mitre.org/data/definitions/89.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins7b608_hardcoded_sql_expressions.html
   Location: ./suppliez_orders.py:11:1J
10      global order_total
11      conn.execute(’IWSERT INTO orders lsuppliez, item, quantity, received) VALUES {'%s', '%s', %d, 0)" 8 (supplier, item, quantity))
12      ozder_total+=quantity


>> Issue: 1B605:start_process_with_a_shell] Starting a process with a shell, possible injection detected, security issue.
   Severity: High   Confidence: High
   CWE: CWE-78 (https://ewe.mitre.org/data7de€initions/78.html)
   More Info: https:7/bandit.readthedocs.io/en/1.9.4/plugins/b60S_start_proeess_with_a_shell.html
   Location: ./supplier_orders.py:21:4
20  def notifyWarehouse{suppliez):
21      os.system("echo notifying warehouse about    + supplier)
22


>> Issue: (B110:try_except_pass] Iry, Except, Pass detected.
   Severity: Low   Confidence: High
   CWE: CWE-703 {https://cue.mitre.org/data/definitions/702.html}
   More Info: https:7/bandit.zeadthedocs.io/en/1.9.4/plugins7bl10_try_except_pass.html
   Location: ./supplier_orders.py:27:4
26          conn.execute(”DELETE FROM orders WHERE zeeeived = 1’)
27      except Exception:
28          pass
29



Code scanned:
    Total lines of code: 29
    Total lines skipped (#nosec): 0
    Total potential issues skipped due to specifically being disabled Ce.g., #nosec BXXXI : 0

Run metrics:
    Total issues (bY severity):
        Undefined: 0
```

```
        Low: 1
        Medium: 1
        High: 1
    Total issues (by confidence):
        Undefined: 0
        Low: 0
        Nedium: 1
        High: 2
he s sk1pped {0) :
```

bandit_aher.txt

```
[moinl  INFO     profile include tests: Bone
[main]  INFO     profile exclude tests: None
[mainl  INFO     cli include tests: Mone
[mci 1  Imro     cli exclude tests: Mone
[main]  INFO     running on Python 3.12.3
Run started:2026-10-30 07:21:57.25972a+00:00

Test results:
    No issues identified.

Code scanned:
    Total lineg of code: 48
    Total lines skipped (#nosec): 0
    Total potential issues skipped due to specifically being disabled (e.g., Onosec BXXX): 0

Run metrics:
    Total issues (by severity):
        Undefined: 0
        Low: 0
        Medium: 0
        High: 0
    Total issues (by confidence):
        Undefined: 0
        Low: 0
        Medium: 0
        High: 0
Files skipped (0):
```

flake8_before.txt

```
supplier_orders.py:5:80: E501 line too long (122 > 79 characters)
supplier_orders.py:11:80: E501 line too long (131 > 79 characters)
supplier_orders.py:12:16: E225 missing whitespace around operator
supplier_orders.py:32:80: E501 line too long (87 > 79 characters)
```

flake8_aher.txt

```
(empty: no issues reported)
```

4. Results after fixing

Pylint (after)

```
$ pylint supplier_orders.py

-----------------------------------
Your code has been rated at 10.00/10
```

Flake8 (aher)

```
$ flake8 supplier_orders.py && echo 'flake8: no issues'
flake8: no issues
```

Bandit (aher)

```
$ bandit -r supplier_orders.py
[main]  INFO    profile include tests: None
[main]  INFO    profile exclude tests: None
[main]  INFO    cli include tests: None
[main]  INFO    cli exclude tests: None
[main]  INFO    running on Python 3.12.3
Run started:2026-10-30 07:21:57.259723+00:00

Test results:
    No issues identified.

Code scanned:
    Total lines of code: 48
    Total lines skipped (#nosec): 0
    Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXX): 0

Run metrics:
    Total issues (by severity):
        Undefined: 0
        Low: 0
        Medium: 0
        High: 0
    Total issues (by confidence):
        Undefined: 0
        Low: 0
        Medium: 0
        High: 0
Files skipped (0):
```

Program output still correct

```
ïNF0: 0idel T lecezved: ok
not îtying waielJorise aGout Ac+re
```

Tool	Before	After
Pylint	2.41/10	10.00/10
Bandit	3 issues (1 High, 1 Medium, 1 Low)	0 issues
Flake8	4 issues	0 issues

5. Reflection

Q1. Which issues were the easiest and hardest to fix?

Style issues from Flake8 and the missing docstrings were the easiest, since they only needed formatting and short text. The hardest were the design changes: removing the global omete£ coca1 Without changing behavior, and the shell call. My first fix, subp £oces s . run, still triggered three Bandit warnings, so I removed the external process altogether.

Q2. Did the tools report any false positives or unhelpful warnings?

Mostly no. The shell call and the SQL string building were real risks. The Bandit warnings about importing subp £oces s (B404) and a partial executable path (B607) are cautionary rather than real bugs here, because the arguments were fixed. Pylint's constant-naming warning for omete£ Lof a1 was a judgment call, since it was really mutable state, and that pointed to a genuine design smell.

Q3. How could static analysis be integrated into a real development workflow?

Run the tools in an editor plugin for instant feedback, in a pre-commit hook so bad code never gets committed, and in a CI pipeline (for example GitHub Actions) that fails the build on Bandit findings, a Pylint score below a threshold or any Flake8 error. Teams should agree on one configuration so results are consistent.

Q4. What tangible improvements did you see in the code?

Security: SQL injection and command injection are gone and failures are logged instead of hidden. Readability: snake_case names, docstrings and PEP 8 formatting. Maintainability: no global state, no shadowed variables, and a main guard so the module can be imported and tested. The Pylint score rose from 2.41 to 10.00 and Bandit and Flake8 now report nothing, while the program output is unchanged.